

# Attack Surface Discovery in Penetration Testing

## Literature review of IoT Architecture regarding Penetration Testing

Timothy Bates  
CIS5396 Ethical Hacking and  
Penetration Testing  
University of West Florida  
Pensacola Florida, US  
tdb41@students.uwf.edu

### ABSTRACT

The digital world has compounded in complexity as every business in every sector depends on an IT infrastructure in some way shape or form. Cyberthreats have become more impactful and disruptive than ever before, and as they continue to evolve in complexity and severity organizations must meet the challenge with their security postures. The primary purpose of this research paper is to examine the critical role that attack surface discovery plays in the multifaceted process of penetration testing. Highlighting its importance in the identification and mitigation of vulnerabilities that could cripple an organization's operations if they were exploited by hackers. Systematically uncovering and documenting the relationships between the various assets of a network allow the attack surface to be discerned, this process is essential in the subsequent steps of penetration testing which ultimately contributes to an organizations understand of, and ability to secure their environment.

The study, and the literature chosen to review, provide a detailed exploration of penetration testing methodologies and processes. IoT architectures are relevant and modern examples of a complex IT infrastructure that requires comprehensive attack surface discovery to be effective. The study demonstrates a methodology that is zone-based for breaking down a layered ecosystem into distinct zones to pinpoint vulnerabilities such as physical tampering risks, network data interception, and unauthorized access at the user-interface level. It highlights the importance of understanding the correlation between identified vulnerabilities and exploitative attack vectors, offering a strategic framework for crafting proactive defenses.

The overall conclusion finds that attack surface discovery is a foundational part of penetration testing and a continuous and ongoing process for the continued

visibility and security of the vulnerable parts of a network. Advanced tools like Nmap, OWASP, and WHOIS can be leveraged to discover details of target network, enumerate the attack surface, and visualize and categorize vulnerabilities and the intricate dependencies of assets within an infrastructure. The details of the research reinforce the idea of the necessity of adopting a proactive and layered approach to cybersecurity. This is to ensure resilience against increasingly sophisticated attacks, and the effectiveness in testing and hardening an organization's security posture in modern digital ecosystems.

### Keywords

Cybersecurity, penetration testing, attack surface discovery, vulnerability management, ethical hacking, network security, IT infrastructure security, security posture assessment, threat analysis, reconnaissance techniques, IoT security, internal attack vectors, external attack surface, risk mitigation strategies, Nmap, OWASP ZAP, Burp Suite, Maltego, Netlas Discovery Tool, Sublist3r, Amass, Assetfinder, DNS analysis, WHOIS lookups, SSL certificates, subdomain enumeration,

FirstName Surname, FirstName Surname and FirstName Surname. 2018. Insert Your Title Here: Insert Subtitle Here. In *Proceedings of ACM Woodstock conference (WOODSTOCK'18)*. ACM, New York, NY, USA, 2 pages. <https://doi.org/10.1145/1234567890>

### Introduction

Cybersecurity is a consistently a rapidly developing field with advancements being made all the time, organizations of any industry face a concerning increase in threats that aim not only to disrupt their business operations and expose sensitive data, but often target the very foundations of their IT infrastructure in critical ways. To accomplish this cybercriminals and other threat actors are constantly testing the security of an

infrastructure for new vulnerabilities to exploit. A critical aspect to organizations defending against these consistent threats is understanding the attack surface of their infrastructure that hackers seek to exploit. This can be accomplished through network penetration testing, which has the primary aim of identifying vulnerabilities before they become exploited to proactively fix them. This is done through the simulation of a potential attack to identify vulnerabilities that may be harder to find than simple vulnerability assessments [1].

Overall, a network penetration test offers several benefits to an organization, it helps them understand their network baseline, stress tests security posture, helps prevent vulnerability exploits, and assists in ensuring network and system security. Network baselines are a comprehensive view of the functional security controls, known existing vulnerabilities, and additional basic infrastructure information, this acts as a square one for details the organization should already be aware of. Stress testing the security posture is a unique benefit and offers a unique importance; because a penetration test's goal is to breach the network and exploit vulnerabilities that have been enumerated it shows a real example of how an organizations security standards and procedures would hold up to the actions of a hacker. Preventing the possibility of network and data breaches are a direct result of successful penetration testing assisting a business by allowing them to adjust risk assessments and mitigation strategies to account for the vulnerabilities that were discovered and exploited. This ultimately ensures the network and system security of an organization by hardening their security posture and enhancing their security strategies. [1].

There are four main steps that are key to the penetration testing process. Information gathering and client expectations, this is the introduction portion that is primarily about setting the goals for the penetration test and how the process will proceed. [1] This is important to ensure the testing does not disrupt business operations of the client and that expectations of actions and possible results are maintained. The subsequent step is reconnaissance and recovery, this is where network scans are conducted, and port and asset information are discovered in order to define the attack surface. The goal of this is to spot vulnerabilities in the organizations defined attack surface to be able to target them for exploitation. The third step is performing the network penetration testing based on the vulnerabilities that were discovered in the

previous step. The tools used to accomplish this depend on the vulnerabilities discovered but the most critical will generally be the focus. The final step in the penetration testing process is reporting and recommendation. This is where the knowledge gained from discovering and leveraging the exploits against a system is compiled into a report and given to the organization. Recommendations and remediation may also be suggested to help mitigate the vulnerabilities found in the process.

As stated earlier, Attack surface discovery is a component in the process of penetration testing. This component is conducted in one the earlier steps, the reconnaissance process, and is leveraged comprehensively on all the assets within an organization's IT infrastructure. This is done to determine the assets within that infrastructure that are exploitable and therefore vulnerable to attack both internally and externally. In this paper we will detail the methodologies and various tools used in the attack surface discovery process by penetration testers. Pen Testing is ultimately an industry application of ethical hacking, which is the practice of simulating cyberattacks to find and address vulnerabilities in an IT infrastructure. There are various tools and techniques that exist for this, including network scanning, web application testing, and foot printing. Ultimately, the aim of this paper is to explore the significance of attack surface discovery and the role it plays within penetration testing, demonstrating its crucial role in enhancing the security posture of an organization by the systematic combing through of assets to discovery and address potential vulnerabilities before they can be exploited.

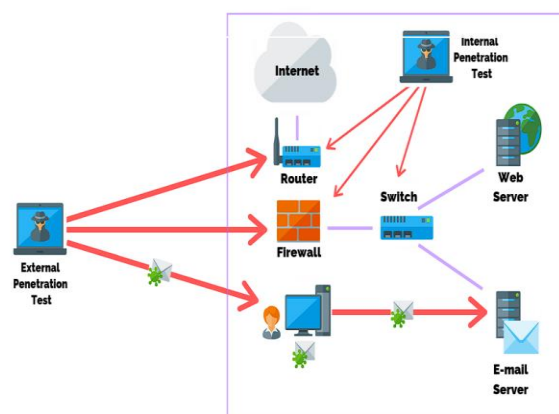


Figure 1: Example from [1] of an IT infrastructure and Penetration testers

## Literature Review

The primary literature source to be reviewed in this information research paper will be the research article "Identifying the attack surface for IoT network" by Syed Rizvi and colleagues. In the evolving landscape of cybersecurity, the identification and management of an organization's attack surface has emerged as a pivotal component of effective security strategies. As discussed, the attack surface of a network sums up all the penetration points, both internally and externally, otherwise known as attack vectors, that can be leveraged by cyber threats and exploited. Attack surface discovery, one of the critical steps in the reconnaissance phase of the penetration testing process, allows for the assessment of these potential vulnerabilities.

The information technology landscape is constantly evolving, Internet of Things (IoT) architectures have become much more common place with contributes to the amplification in complexity of cybersecurity challenges, IoT infrastructures are the result of modern business solutions needing to be varied and complex to meet modern demand; hardware can vary from standard database and application servers servicing users on a geographically local network, to cloud mixed cloud based solutions that can have users and administrators geographically dispersed and needing secure remote connections to various aspects of the network, and any combination or blend of the two. The complexity increases further with even more devices in the modern day connecting to the internet, from wireless security cameras to internet capable appliances these all represent possible attack vectors that should be accounted for if present in the architecture. These devices, which often transmit data autonomously, can slip past the discovery and documentation process thus leaving a potential entry point for cyberattacks.

The seamless integration of IoT devices into a vast majority of critical business sectors from healthcare to defense amplifies this need as a critical issue. In their seminal work, Syed Rizvi and colleagues [3] delve into the complexities of securing IoT networks by systematically defining and analyzing their varied and complex attack surfaces. This research can offer critical insights into the methodologies necessary for identifying and mitigating vulnerabilities within such networks. The ability to uncover such vulnerabilities is pivotal for developing effective

penetration testing strategies that will be effective to these modern complex architectures.

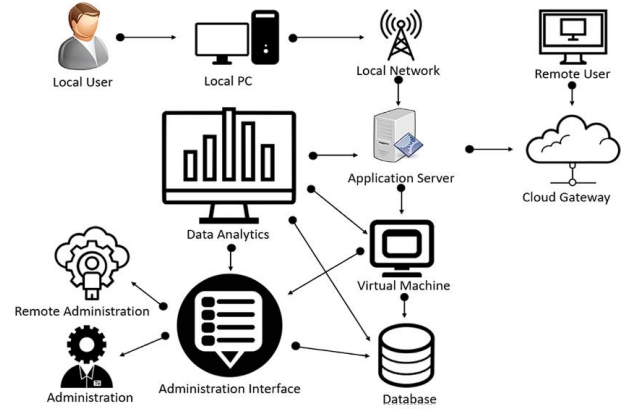


Figure 2: Generic IoT Network Architecture with multiple different assets from [3]

The research paper details a methodology that involves deconstructing IoT architectures into several different zones, assessing for particular security vulnerabilities. Zone-based analysis is integral for categorizing the varied components of an IoT network. Divisions by zone allows each zone to be a segmentation of a distinct layer of the IoT ecosystem, this can range from user-interface elements to the physical device, or the network layers of an ecosystem. [3] This structured approach allows the researchers to pinpoint vulnerabilities that are unique to each layer, such as physical tampering risks at the device level, data interception attacks at the network layer, or unauthorized access and privilege escalation through the user interface.

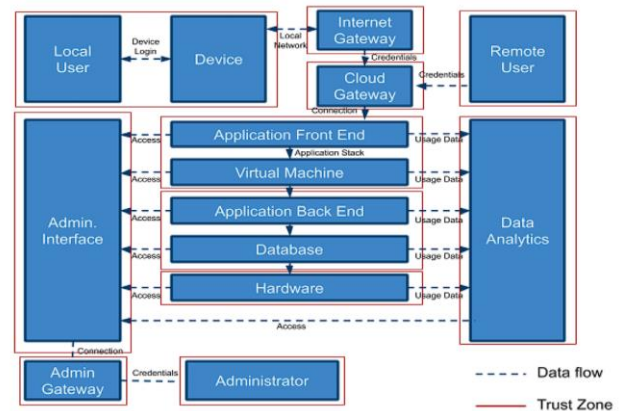


Figure 3: Network divided into Zones for attack surface discovery based on trust from [3]

Additionally, the study explores the correlation between vulnerabilities discovered and the attack vectors that can exploit those weaknesses. A primary focus on this analysis isn't simply categorizing vulnerabilities but understanding how they could be leveraged as exploits in real-world scenarios to help harden the network and improve incident response. For example, in the user-interface zone a vulnerability in training scheme might be exploited by phishing campaigns to expose login credentials. This could allow threat actors to gain remote access to a system and put critical assets at risk depending on users' privileges. This real-life applicable focus on vulnerabilities and their exploitative attack vectors is crucial for devising effective defensive strategies and a fundamental principle of what makes penetration testing effective. This aids in visualizing the attack surface and more importantly mapping the possible attack pathways within the network that hackers might try to exploit, therefore offering a degree of proactive mitigation.

Another purpose this serves is to facilitate the strategic design of countermeasures that can be integrated into the design process of IoT systems. Diverse and complex attack surfaces will require diverse and layered security measures and integrating these earlier into the design process not only enhances functionality but allows IoT networks to strive towards secure by design. The proactive approach is critical as the diverse nature of the devices can otherwise lead to significant management and security problems in discerning the attack surface.

The insights provided by the research paper would prove to be instrumental in advancing the discourse on cybersecurity strategies within IoT contexts. This is important due to the increasing frequency of IoT architectures being more common in a variety of industries. Breaking down the methodologies used to analyze such architectures helps in contributing to a robust framework to how to handle essential security components in penetration testing. Their work highlights the unique challenges of IoT security and highlights the benefits of an integrated security strategy that addresses both the diverse technologies involved and the various stakeholders that operate within the system from developers to administrator to end-users. The comprehensive framework proposed by the researchers enhances our understanding of IoT attack surfaces and informs the development of more resilient cybersecurity solutions that can adapt to the evolving

threats and vulnerabilities that modern IT infrastructures face.

This literature review summarizes the main topics of the chosen research paper, demonstrating the intricate and evolving nature of attack surfaces in respect to modern example using IoT networks and underscoring the importance of comprehensive security strategies and how they contribute to hardening an infrastructure against cyberattack. As IoT devices become more pervasive across a vast majority of business sectors, understanding and securing the attack surface becomes more critical. This research contributes significantly to that pursuit, providing a detailed roadmap for identifying attack surfaces and rooting out vulnerabilities while also crafting strategic responses that can protect IoT infrastructures from ever increasing sophisticated cyber threats.

**Table 1**  
Categorizing Devices with respect to IoT domains

| IoT Domains    | IoT Devices                                                                                                                                     | Consumer                             | Commercial    |
|----------------|-------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------|---------------|
| Home           | Alexa (Hd1);<br>Google Home (Hd2);<br>Amazon Echo (Hd3);<br>Cortana (Hd4);<br>Nest Thermostat (Hd5);<br>Nest Camera (Hd6);<br>Philips Hue (Hd7) | Hd1, Hd2, Hd3, Hd4, Hd5,<br>Hd6, Hd7 |               |
| Wellness       | Pacemakers (Wd1);<br>Fitbit (Wd2);<br>Insulin Pump (Wd3)                                                                                        | Wd1, Wd2, Wd3                        |               |
| Transportation | Automatic Braking (Td1);<br>Self-Steering (Td2);<br>Vehicle Fleet Monitoring (Td3)                                                              | Td1, Td2                             | Td3           |
| Commerce       | Point of Sale (Cd1);<br>Inventory Management (Cd2);<br>Square Reader (Cd3)                                                                      |                                      | Cd1, Cd2, Cd3 |
| Financial      | ATM (Fd1);<br>Venmo (Fd2)                                                                                                                       |                                      | Fd1, Fd2      |
| Industrial     | SCADA (Id1);<br>PLCs (Id2)                                                                                                                      |                                      | Id1, Id2      |

**Figure 4: Categorized devices with respect to domains in IoT network [3]**

## Methodology

This section will cover the methodologies and techniques used in penetration testing and explore their effectiveness during the attack surface discovery phase within a network environment. Given the often-complex nature and diversity of modern IT infrastructures it is critical to have a robust approach to the systematic identification of possible vulnerabilities to be able to visual the full attack surface of a network. Any vulnerabilities that are missed could prove to be a critical flaw. Pen testing is essential to help maintain security standards and progress

the defense aspects of cybersecurity. This process aims not only to expose exploitable weaknesses but provide true insight for strengthening the network against real threats. Simulating these potential exploits to gauge their practical impact is essential to that. As stated, the main stages of penetration testing are information gathering, reconnaissance and discovery, exploitation, review and results. Depending on the depth of the testing and the network this process can be conducted in three primary categories, black box, gray box, and white box testing. [1].

### Penetration Testing Methodologies

These three approaches offer unique benefits and can be utilized to better perform in different testing scenarios depending on need. Black box testing is meant to imitate the perspectives and actions of an external attacker that has little, or no prior knowledge of the system being targeted. The benefit to this is that it focuses on the identification and exploitation of the external attack surface. [2] These are assets that are visible externally, such as exposed services, open ports, or web application vulnerabilities. This is especially effective in assessing perimeter defenses such as intrusion detection systems (IDS) and firewalls.

Gray box testing is a middle ground, as it is designed to replicate the perspective of an internal user who has some access to resources within the network. This provides a contrasting simulation as the threat actor would combine external reconnaissance with internal knowledge targeting both the internal and external attack surface, from an external perspective. By operating in this fashion gray box penetration testing focuses on both internal and external vulnerabilities such as improper access control that can lead to privilege escalation attacks. [1] This approach is particularly beneficial for uncovering security flaws that could be exploited by disgruntled/former employees or external attackers who have gained some level of access to the internal network through external exploits.

The last method, white box testing is the most comprehensive of all penetration testing methodologies by providing the tester with complete knowledge of the network, including all documentation, configuration files, and source code. This is albeit the most unrealistic for a majority of cyberthreats but is also the most thorough at uncovering vulnerabilities as it tests every level of the network with a full exposure to the attack surface. White-

box testing is time intensive while also requiring significant resources from both the testers and the organization it provides the most in-depth assessment of that organizations security posture and ultimately ensures that the system is hardened against critical cyber-attacks. This approach is ideal for organizations aiming to identify and remediate vulnerabilities proactively, rather than reacting to breaches after they occur.

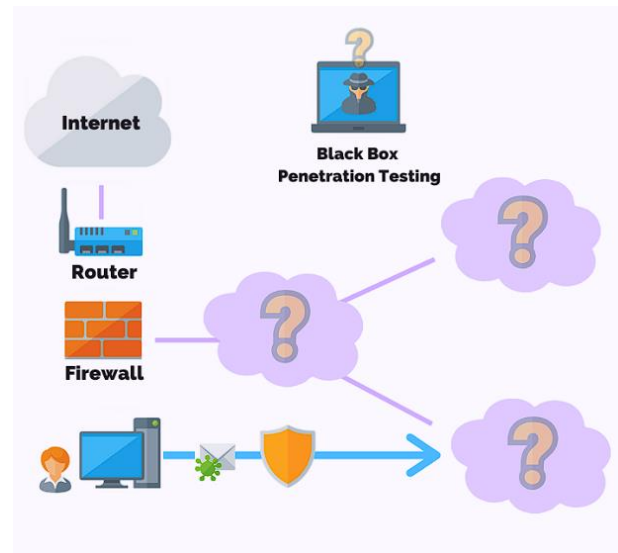


Figure 5: Blackbox testing diagram from [1]

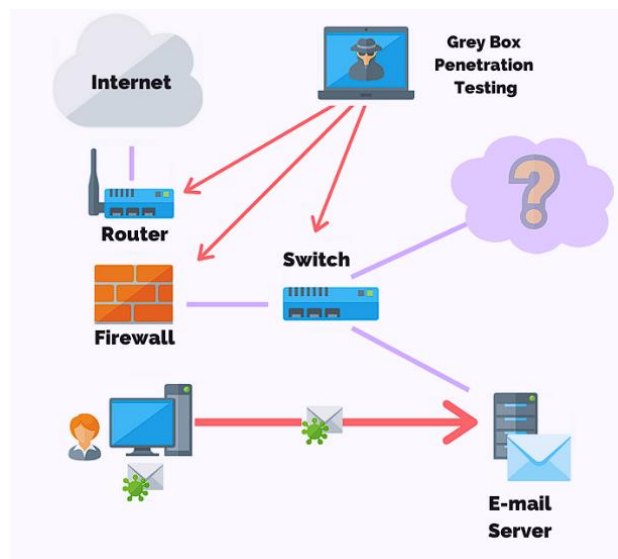


Figure 6: Graybox testing diagram from [1]

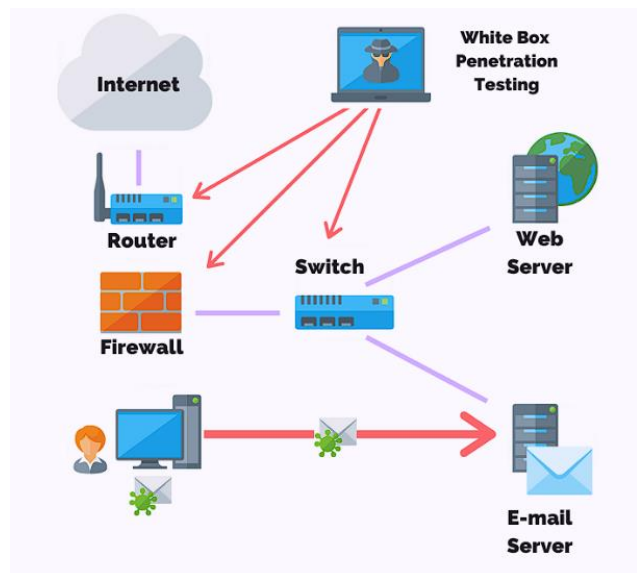


Figure 7: Whitebox testing diagram from [1]

### Key Data Sources for Attack Surface Discovery

While the discovery process comprises the identification and listing of all potential attack vectors within a network, mapping expands on this by visualizing the relationship between a network and the entities that comprise it. This was outlined as in in-depth benefit to penetration testing on IoT networks due to their complexity but is applicable to any IT infrastructure. This is because the further detailed approach provides a clear understanding of the interconnection vulnerabilities in the attack surface can have and can offer insights towards the layered defense necessary to mitigate them. To map an attack surface effectively, various data sources are used to uncover relationships between network assets. These sources include:

#### WHOIS Databases

WHOIS provides information on the ownership of IP addresses and domain names. It reveals details such as the registrant's name, contact information, and registration dates. This is critical for understanding asset ownership

#### DNS Records

DNS databases store mappings for forward and reverse lookups. Forward lookups translate domain names into IP addresses, while reverse lookups convert IP addresses back into domain names. These are often the target of

cyber-like DNS poisoning to try to expose sensitive data. Analyzing DNS records helps reveal the structure and connections within a network.

#### SSL Certificates

SSL certificates are a valuable resource for identifying domain names associated with an organization. They also provide information about organizational units and connections between entities within a network

### Attack Surface Discovery Tools

Several tools exist to penetration testers to aid in the process of mapping an attack surface. These tools help root out some of this sensitive data and can help visualize the relationships between network entities. Data Access Tools, like WHOIS, DNS lookups, and SSL certificate search engines can be used to access this raw data. Graphical tools to create detailed maps allow the penetration testing team to visually relate the asset relationships in a network and pinpoint potential risks. Maltego is an example of a relationship mapping tool that can offer drag and drop functionality to visualize connections between entities. Microsoft Visio and Netlas Discovery tools are different examples of diagram tools, the latter of which is specifically designed for attack surface management. [2]

### Subdomain Enumeration Tools

Enumeration of subdomains is a specific yet critical step in attack surface discovery, as they represent a less obvious point of entry in possibly poorly secured or deprecated sections of an organization's network. There are several tools that exist for this such as:

#### Sublist3r

Python-based tool that automates the discovery of subdomains by querying multiple search engines and DNS services.

#### Amass

Known for its scalability, Amass performs in-depth subdomain enumeration by combining passive and active methods. It also integrates with WHOIS and DNS databases to provide comprehensive results.



## **Asset-finder**

Asset-finder specializes in finding subdomains tied to a root domain, making it ideal for rapid reconnaissance, due to its focus on speed and simplicity.

## **Network Scanners**

Network scanners are used to probe external IP ranges and detect open ports, services, and live hosts. These tools help identify potential vulnerabilities at the network layer.

### **Nmap (Network Mapper)**

Nmap scans networks to identify open ports, running services, and even potential operating systems. It provides detailed output and is importantly applicable to a wide variety of diverse networks

### **Masscan**

Port scanner optimized for speed, Masscan can scan entire IP ranges at an exceptionally fast rate, making it ideal for large-scale reconnaissance, though less detailed than Nmap

## **Web Application Scanners**

Web application scanners focus on identifying web-based security flaws. Given the prevalence of web applications in modern IT environments, this category of tools is essential for attack surface discovery.

### **OWASP ZAP (Zed Attack Proxy)**

An open-source tool. Designed to identify common vulnerabilities such as SQL injection and cross-site scripting (XSS). OWASP ZAP provides both automated and manual testing.

### **Burp Suite**

A robust and varied platform for web application security testing, Burp Suite offers advanced features such as request interception, automated vulnerability scanning, and manual testing tools for custom payloads.

## **Mapping An Attack Surface**

Now that we have outlined the tools used in attack surface discovery and some of the data that is necessary to

obtain an understanding of the relationships between entities within the network, now we can detail the steps of mapping the attack surface. Attack surface mapping involves a structured series of systematic steps designed to thoroughly evaluate a network's vulnerabilities. Due to the diverse nature of IT infrastructures, there are multiple ways to go about enumerating the attack surface of a network, this is simply a structured example of one approach. The first step begins with searching for root domains through a WHOIS lookups tool, this can help identify an organization's primary domains. These domains are the rough foundation of an attack surface and are a starting point for further discovery. Root IP addresses linked to this domains are uncovered through the WHOIS lookup tool. This can help define the external facing assets that will be the target of initial attacks.

Subdomain enumeration continues the process, as this expands the scope of the discovery to try and uncover less secure or overlooked subdomains in the organizations infrastructure that could serve as entry points into the internal network. This can often be a source of vulnerability in a network because some sub domains are often neglected in the security posture of an organization if they are old, deprecated or simply just overlooked. Following up on this, forward and reverse DNS lookups are performed to translate domain names and IP addresses gathered in earlier discovery phases. This can reveal misconfigured domains and uncover useful dependencies within the target network.

The mapping process can also include vertical expansion, this extends the analysis of additional layers of infrastructure within the target network. Services, assets, and dependencies between discovered entities on the attack surface are identified and vulnerabilities that would not be as easily apparent are uncovered. This allows for a lot of lateral movement through exploiting external vulnerabilities that could have critical dependencies that lead to accessing the internal network.

After comprehensive identification of vulnerabilities and the severity of their potential exploitation result analysis is conducted. This is to filter out irrelevant assets and categorize the relevant components, as it is simply reality that not all assets within an IT infrastructure are going to be vulnerable or even relevant to the penetration testing. The goal achieved by this is to refine the attack surface to only include elements that would pose a genuine risk to the organization if exploited.

This process of attack surface discovery is comprehensive, and multilayered to ensure that an organization's IT infrastructure is fully examined at all aspects and a thorough attack surface is identified and the potential vulnerabilities analyzed. This foundational step is crucial for the penetration test to be effective, as missing possible aspects of the attack surface could cause critical vulnerabilities to go unnoticed and dampen the effect of the penetration test on the overall security posture of the organization.

## Results and Conclusion

Exploring the various aspects of attack surface discovery reveals its critical role within the penetration testing process. Systematic and thorough identification of assets both internally and externally, organization of vulnerabilities and the understanding of in-depth dependencies that can lead to security gaps are all a part of defining an infrastructure attack surface. Mapping this surface through strict methodologies such as identifying primary domains, enumerating branching subdomains, and vertical relationship analysis were all shown to have an impact in the process of identifying attack vectors. A modern complex IT environment has both internal and external attack surfaces that must be accounted for. There are various network scanning tools like Nmap that allow for precise analysis of a network by penetration testers to help simulate real world cyber-threats to ensure a network's security posture is hardened to the weaknesses pinpointed in the discovery phase. Ultimately, this research underscores that attack surface discovery, when executed thoroughly, not only enhances the penetration testing process as a whole, but also strengthens an organization's ability to proactively defend against and mitigate cyber threats. A thoroughly created attack surface map allows an organization to reduce response times, correct misconfigurations, and implement layered defense to help achieve security by default status against vulnerabilities.

In conclusion, the informative study reinforces the idea that attack surface discovery lays the groundwork for subsequent phases of penetration testing on a network. Organizations are properly geared to counteract potential threats before they happen when they have a true understanding of the internal and external aspects of their networks and the security flaws between them. The literature review shows how modern diverse IT infrastructure requires comprehensive and thorough

solutions to secure them. Future advancements in discovery tools and techniques will continue to enhance this process and provide new opportunities to address emerging vulnerabilities in increasingly complex IT infrastructures.

## REFERENCES

- [1] J. Firch, "Network Penetration Testing: A Beginner's Guide to Cybersecurity Testing," PurpleSec, <https://purplesec.us/learn/network-penetration-test/>, (accessed Nov. 22, 2024).
- [2] Netlas, "Attack Surface Discovery: A Comprehensive Guide," Netlas, [https://netlas.io/blog/attack\\_surface\\_discovery\\_guide/](https://netlas.io/blog/attack_surface_discovery_guide/), (accessed Nov. 22, 2024).
- [3] Syed Rizvi, R.J. Orr, A. Cox, P. Ashokkumar, and M.R. Rizvi, "Identifying the attack surface for IoT network," *Internet of Things*, vol. 9, Article no. 100162, pp. 1-18, Jan. 2020. [Online]. Available: <https://doi.org/10.1016/j.iot.2020.100162>
- [4] BreachLock, "The 11-Step Pen Test Plan," BreachLock, <https://www.breachlock.com/resources/blog/the-11-step-pen-test-plan/>, (accessed Nov. 22, 2024).